

Moving off server-side sessions

We spent most of last week on the load test results and the picture was pretty clear.

The session store was the bottleneck. Once we got past roughly 400 requests per second, the lookup on every single request started queueing and p99 latency went from 40ms to well over a second. Adding read replicas helped a bit but it moved the problem rather than solving it — we were still doing a network round trip per request just to find out who the caller was.

So we're dropping server-side sessions and going with stateless JWT. The token carries the claims we actually need, we verify the signature locally, and there's no lookup at all on the hot path. Refresh tokens stay server-side because we need to be able to revoke them, but those are touched maybe once an hour per user rather than on every request.

The tradeoff we're accepting is that we can't invalidate an access token before it expires. We're setting the access token TTL to 15 minutes to keep that window small.

— Basuru, 2026-05-14